

Advanced Infrastructure Protection

Security in Cloud

Foundational Concepts

Introduction to Security



Confidentiality

Ensuring that sensitive information is accessible only to those authorized to have access. It is the protection of data from unauthorized disclosure.



Integrity

Maintaining and assuring the accuracy and completeness of data over its entire life cycle. Data must not be changed in transit or by unauthorized people.



Availability

Guaranteeing reliable access to information and resources by authorized users. Security systems and data must be available when needed.

Cloud Defense Architecture

Cloud Security Models

Shared Responsibility

Security 'of' the cloud (provider) vs security 'in' the cloud (customer). Understanding the demarcation line is critical for compliance.

Identity Management

Implementing Zero Trust architectures where every access request is strongly authenticated, authorized within policy, and inspected.

Continuous Monitoring

Real-time visibility into infrastructure health, logging API calls, and automated threat detection across distributed workloads.

Strategic Engineering

Security Design Principles

Defense in Depth

Implementing multiple layers of security controls throughout an information system. If one layer fails, others remain to protect the environment.

Least Privilege

Ensuring that users and systems have only the minimum level of access necessary to perform their functional requirements, limiting potential blast radius.

Fail-Safe Defaults

Design systems to deny access by default. In the event of a failure, the system should revert to its most secure state rather than remaining open.

Cloud Defense Architecture

Shared Responsibility Model

Responsibility of the Provider

The cloud service provider is responsible for the security 'of' the cloud. This includes protecting the global infrastructure that runs all the services offered in the cloud: hardware, software, networking, and facilities.

Responsibility of the Customer

The customer is responsible for security 'in' the cloud. This includes managing data, identity and access management, operating systems, network and firewall configuration, and client-side encryption.

Activity Session

Shared Responsibility Model

Group Exercise: Demarcation

Work in pairs to map specific security tasks to either the Provider or the Customer based on different service models (IaaS, PaaS, SaaS).

- Identify 3 hybrid responsibilities
- Define the "Line of Ownership"

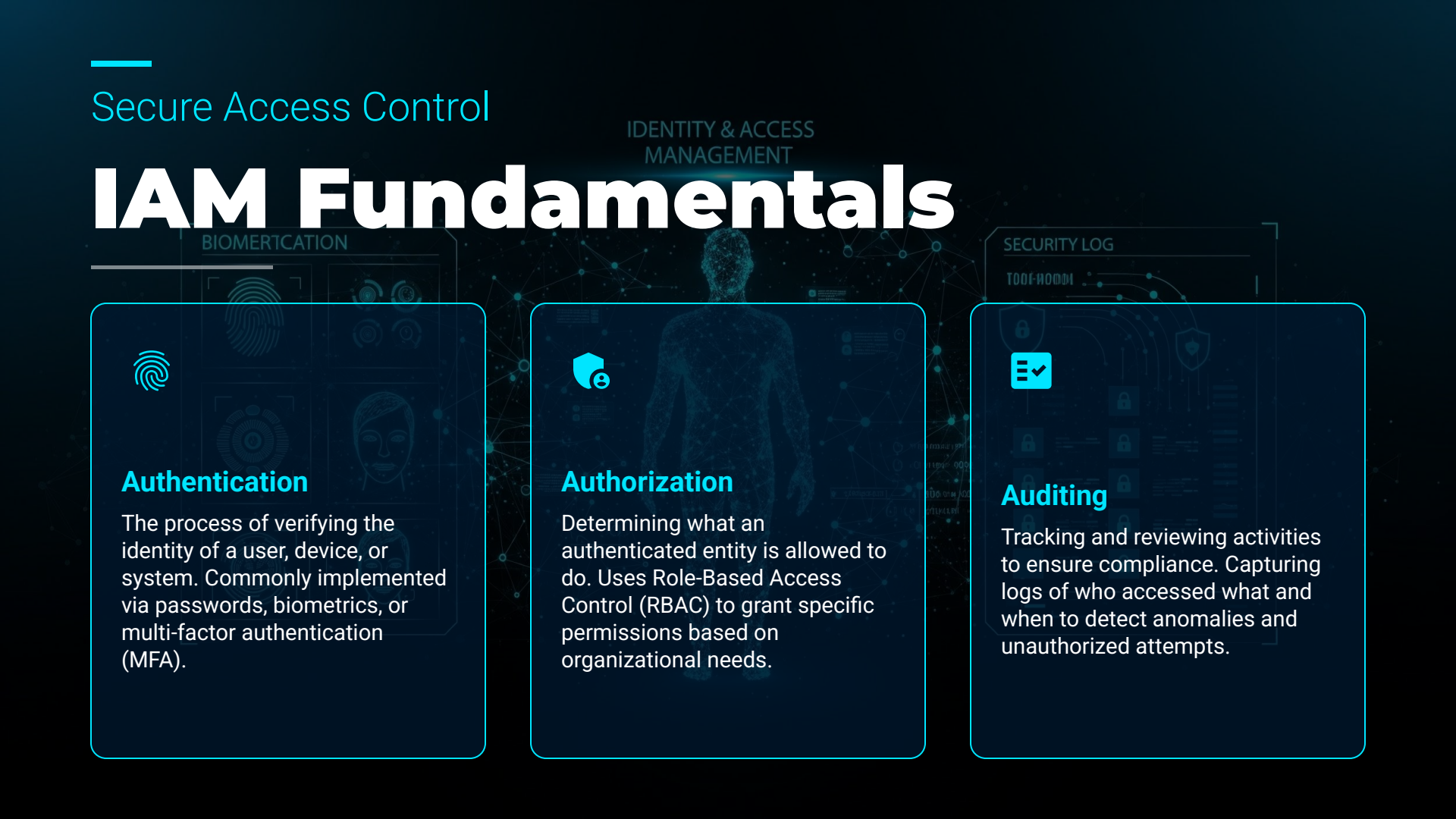
Case Study Analysis

Review a hypothetical data breach scenario and determine which party failed to meet their contractual security obligations.

- Evaluate root cause analysis
- Assess compliance impact

Secure Access Control

IAM Fundamentals



Authentication

The process of verifying the identity of a user, device, or system. Commonly implemented via passwords, biometrics, or multi-factor authentication (MFA).

Authorization

Determining what an authenticated entity is allowed to do. Uses Role-Based Access Control (RBAC) to grant specific permissions based on organizational needs.

Auditing

Tracking and reviewing activities to ensure compliance. Capturing logs of who accessed what and when to detect anomalies and unauthorized attempts.

Secure Access Control

Authenticating & Authorizing



IAM Authentication

The critical first step of verifying the identity of a user, service, or application.

- Multi-Factor Authentication (MFA)
- Biometric Verification
- Digital Certificates & Keys



IAM Authorization

The process of granting specific permissions to an authenticated identity to interact with resources.

- Role-Based Access Control (RBAC)
- Attribute-Based Access (ABAC)
- Policy-Driven Enforcement

Secure Access Control

IAM Authorization Examples

Role-Based (RBAC)

Permissions assigned based on job functions.

- Cloud Administrator
- Database Operator
- Security Auditor

Attribute-Based (ABAC)

Dynamic access via tags and attributes.

- Project=Confidential
- Region=US-East
- Environment=Prod

Policy Enforcement

JSON-based logic to allow or deny actions.

- S3:GetObject
- EC2:TerminateInstance
- IAM:CreateUser

Secure Access Control

Advanced IAM Services

Secrets Manager

Centralized storage for API keys, passwords, and certificates. Automates rotation and removes hard-coded credentials from applications.

Directory Service

Managed Microsoft Active Directory in the cloud. Enables seamless integration with existing on-premises identities and group policies.

Identity Center

Single Sign-On (SSO) service for managing workforce access across multiple accounts and cloud applications from a central portal.

Secure Access Control

IAM Governance & Services

Auth & Access Services

Extending security beyond basics:

- Secrets Manager: Credential rotation
- SSO / Identity Center: Workforce portal
- Directory Service: Managed AD

Using Organizations

Central governance for multi-account environments:

- Service Control Policies (SCPs)
- Consolidated Billing
- Hierarchical OU grouping

Authorizing Examples

Practical policy application:

- RBAC: Role for DB Admins
- ABAC: Project-based access
- Explicit Deny: Block S3 delete

Secure Access Control

Securing Infrastructure

Application Architecture

Three-Tier Web Application Structure

Presentation Tier

The user interface and communication layer.

- Web Browsers
- Mobile Apps
- Content Delivery (CDN)

Logic Tier

Coordinates the application, processes commands, and makes logical decisions.

- Application Servers
- API Gateways
- Microservices

Data Tier

The persistence layer where information is stored and retrieved.

- Relational DBs
- NoSQL Clusters
- Object Storage

Infrastructure Networking

Virtual Private Cloud (VPC)



Isolated Network

Define your own virtual network in a logically isolated section of the cloud.

- IP Address range control
- Subnet creation
- Route table config



Security Layers

Multiple layers of security controls to protect your resources.

- Network ACLs (Stateless)
- Security Groups (Stateful)
- Flow Logs monitoring



Connectivity

Seamless connection options for hybrid and internet access.

- Internet Gateways
- NAT Gateways
- Direct Connect / VPN

Infrastructure Networking

Public & Private Subnets Setup

Public Subnets

Resources accessible from the internet via an IGW.

- Internet Gateway (IGW)
- Public IP Addresses
- Web Tier placement

Private Subnets

Isolated resources with no direct internet ingress.

- NAT Gateway access
- No Public IPs
- DB & App Tier placement

Internet Protocols

Rules governing traffic flow and routing between nodes.

- Route Tables (0.0.0.0/0)
- IPv4 / IPv6 CIDR Blocks
- DHCP Options Sets

Infrastructure Security

Security Groups: Stateful Firewalls

Inbound Rules

Control the traffic allowed to reach your instance.

- Protocol (TCP, UDP, ICMP)
- Port Range specification
- Source IP or Security Group
- Default: Deny all ingress

Stateful Filtering

Automatically allows return traffic for established sessions.

- No need for return rules
- Simplifies rule management
- Track connection state
- Instance-level enforcement

Outbound Rules

Control the traffic allowed to leave your instance.

- Destination IP ranges
- Port-specific egress
- Default: Allow all egress
- Least privilege capability

Infrastructure Security

Network Access Control Lists (ACLs)

Subnet-Level Security

An optional layer of security for your VPC that acts as a firewall.

- Defines rules for subnets
- Stateless filtering
- Evaluates rules in order
- First rule match applies

Stateless Architecture

Does not track connection state; rules required for both directions.

- Inbound rules required
- Outbound rules required
- Explicit allow/deny
- Default: Deny all traffic

Rule Configuration

Rules are numbered starting from 100 for easy insertion.

- Protocol and Port range
- Source/Destination CIDR
- Allow or Deny action
- Evaluation by priority

Infrastructure Networking

Elastic Load Balancing (ELB)

Traffic Distribution

Automatically distributes incoming traffic across multiple targets.

- EC2 Instances
- Containers (ECS)
- IP Addresses
- Lambda Functions

Health Checks

Monitors the health of registered targets for reliability.

- Status checks
- Automatic rerouting
- Fault tolerance
- High availability

ELB Types

Specialized solutions based on your specific traffic needs.

- Application (ALB - L7)
- Network (NLB - L4)
- Gateway (GWLB)
- Classic (Previous Gen)

Infrastructure Security

Protecting Compute Resources

Host Hardening

Minimize attack surfaces by securing the OS and software.

- Disable unused ports
- Remove unnecessary services
- Regular kernel patching
- Custom AMIs / Gold Images

Identity & Access

Control who can access and manage compute instances.

- IAM Roles for EC2
- SSH Key Pair management
- Principle of Least Privilege
- MFA for console access

Monitoring & Audit

Continuous tracking of system behavior and changes.

- CloudWatch Logging
- CloudTrail API auditing
- VPC Flow Logs analysis
- GuardDuty threat detection

Infrastructure Security

Protecting Application Data



Infrastructure Security

Basics of Data Protection

Encryption at Rest

Protects data stored on physical media from unauthorized access.

- AES-256 standards
- KMS key management
- Transparent encryption
- Volume & Disk level

Encryption in Transit

Secures data as it moves between clients, servers, and services.

- TLS/SSL protocols
- HTTPS enforcement
- VPN tunnels
- IPsec security

Durability & Backup

Ensures data availability and recovery in case of failure.

- Automated snapshots
- Cross-region replication
- Versioning control
- Point-in-time recovery

Infrastructure Security

Protect Data at Rest



Storage Encryption

Ensure physical media is secured using industry standards.

- AES-256 Encryption
- EBS Volume Encryption
- S3 Server-Side Encryption
- RDS Database Protection



Key Management

Centralized control over cryptographic keys.

- AWS KMS Integration
- Customer Managed Keys
- Automatic Rotation
- Strict Access Policies



Lifecycle & Recovery

Maintain data integrity through regular snapshots.

- Encrypted Backups
- Snapshot Protection
- Cross-Region DR
- Versioning Controls

Infrastructure Security

What is Amazon S3?

Object Storage Service

Scalable storage for any type of data, accessible from anywhere.

- Scalable & Durable
- Internet-accessible
- Web interface & APIs
- Cost-effective tiers

Buckets & Objects

Organize data in containers called "Buckets" containing "Objects".

- Unique Bucket names
- Metadata tagging
- Versioning support
- Object-level locking

Security & Compliance

Enterprise-grade protection for your most sensitive data.

- IAM & Bucket Policies
- Server-Side Encryption
- Access Analyzer
- Private Link access

Infrastructure Security

Amazon S3 Protection Features

Access Control

Manage who can access your S3 buckets and objects.

- IAM User Policies
- Bucket Policies
- Access Control Lists (ACLs)
- S3 Block Public Access

Encryption

Protect data using server-side or client-side encryption.

- SSE-S3 (Managed Keys)
- SSE-KMS (AWS KMS)
- SSE-C (Customer Keys)
- TLS for data in transit

Governance & Audit

Monitor and enforce compliance for storage resources.

- S3 Object Lock (WORM)
- CloudTrail Logging
- S3 Inventory
- AWS Trusted Advisor

Infrastructure Security

Protection through Encryption

Server-Side (SSE)

AWS encrypts data on your behalf as it is written to disk.

- SSE-S3 (S3 Managed)
- SSE-KMS (Key Service)
- SSE-C (Customer Keys)
- Transparent to user

Client-Side Encryption

Encrypt data locally before uploading to ensure end-to-end privacy.

- AWS Encryption SDK
- S3 Encryption Client
- Complete key control
- Zero-trust architecture

Transit Security

Protect data in motion between your network and the cloud.

- TLS 1.2+ mandatory
- HTTPS enforcement
- Perfect Forward Secrecy
- VPC Endpoints

Infrastructure Security

Protect Data in Transit

Secure Communication

Mandate secure protocols for all data traversing the network.

- TLS 1.2 or higher
- Perfect Forward Secrecy
- HTTPS Enforcement
- Strong Cipher Suites

Private Connectivity

Minimize exposure to the public internet using private links.

- AWS PrivateLink
- Interface VPC Endpoints
- Site-to-Site VPN
- AWS Direct Connect

Edge Protection

Secure data at the network edge and accelerate delivery.

- Amazon CloudFront
- ACM Certificate Manager
- AWS WAF Integration
- DDoS Mitigation

Infrastructure Security

Protect Data in Amazon S3



At-Rest Protection

Secure stored objects through robust encryption and access layers.

- SSE-KMS / SSE-S3
- S3 Object Lock
- Bucket Policies
- IAM Access Control



In-Transit Security

Encrypt data as it moves between your network and S3.

- TLS 1.2+ Mandatory
- HTTPS Enforcement
- AWS PrivateLink
- VPC Endpoints



Monitoring & Audit

Gain visibility into data access and security posture.

- CloudTrail Logging
- S3 Inventory
- Access Analyzer
- Macie PII Discovery

Infrastructure Security

Additional Data Protection Services



Amazon Macie

Discover and protect sensitive data at scale using AI.

- PII Identification
- Automated Data Discovery
- Sensitive Data Insights
- Continuous Monitoring



AWS Backup

Centralized backup service to automate data protection.

- Policy-based Management
- Cross-Region Backup
- Ransomware Protection
- Automated Compliance



CloudHSM

Cloud-based hardware security module for key storage.

- FIPS 140-2 Level 3
- Dedicated Hardware
- Full Control of Keys
- Standard API Support


Infrastructure Security
LOGGING AND MONITORING

Infrastructure Security

Importance of Logging & Monitoring



Operational Visibility

Gain real-time insights into system health and performance metrics.

- Resource Utilization
- Error Rate Tracking
- Latency Analysis



Threat Detection

Identify unauthorized access attempts and anomalous behavior patterns.

- Intrusion Detection
- Policy Violations
- Audit Trail Integrity



Incident Response

Facilitate rapid root cause analysis and forensic investigations.

- Faster Recovery (MTTR)
- Event Correlation
- Compliance Auditing

Infrastructure Security

Capture and Collect

AWS CloudTrail

Capture account activity and API usage across your AWS infrastructure.

- Management Events
- Data Events
- CloudTrail Insights
- Log File Integrity

Amazon CloudWatch

Collect and track metrics, collect and monitor log files, and set alarms.

- CloudWatch Logs
- VPC Flow Logs
- Custom Metrics
- Container Insights

AWS Config

Record and evaluate configurations of your AWS resources.

- Configuration History
- Snapshot Collection
- Resource Relationships
- Change Notifications

Infrastructure Security

Reading a Log File

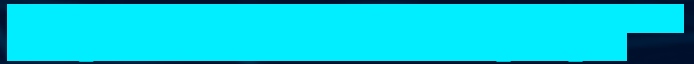
Log Structure Analysis

Log files contain chronological records of events, typically following a specific schema:

- **Timestamp:** When the event occurred (ISO 8601 or Unix).
- **Source:** IP address, service name, or user ID.
- **Action:** The operation performed (e.g., GET, POST, Login).
- **Status Code:** Outcome of the event (e.g., 200 OK, 403 Forbidden).
- **Message:** Detailed description or error payload.

Anatomy of a Log Entry

Common log format example:



- **Filtering:** Use "grep" or "CloudWatch Insight queries" to isolate specific status codes.
- **Correlation:** Match Request IDs across multiple log streams to trace the lifecycle of a single event.

Infrastructure Security

AWS Services with Built-in Logs



Amazon S3

Tracks object-level operations and access requests.

- Server Access Logs
- Object-level API activity
- Lifecycle transitions



AWS WAF

Captures detailed info about web traffic and blocked requests.

- Request timestamps
- Client IP & country
- Rule action (Block/Allow)



Amazon VPC

Records IP traffic flowing to and from network interfaces.

- VPC Flow Logs
- Source/Dest IP & Port
- Accept/Reject status

Infrastructure Security

Monitor and Report

Real-time Alerting

Configure automated notifications based on threshold breaches.

- CloudWatch Alarms
- SNS Notifications
- Anomaly Detection
- Custom Thresholds

Visual Dashboards

Create centralized views for operational and security health.

- CloudWatch Dashboards
- Cross-Region Views
- Metric Correlation
- Performance Graphs

Compliance Reporting

Generate evidence for audits and security posture assessments.

- AWS Config Reports
- Security Hub Insights
- Artifact Documentation
- SLA Monitoring

Infrastructure Security

Governance with AWS CloudTrail

Key Capabilities

CloudTrail provides a comprehensive history of AWS API calls for your account.

- Management Events: Control plane operations.
- Data Events: Resource-level operations (S3, Lambda).
- CloudTrail Insights: Detect unusual API activity.
- Global Reach: Multi-region trail configuration.

Security & Compliance

Ensure the integrity and availability of your audit logs.

- Log File Integrity: Cryptographic validation.
- Log File Encryption: SSE-KMS protection.
- S3 Storage: Durable, long-term log archival.
- Compliance: Supports HIPAA, PCI DSS, and SOC.

Infrastructure Security

Observability with Amazon CloudWatch

Collect & Monitor

Gather metrics and logs from AWS resources and applications.

- System-wide visibility
- Custom metrics
- Log aggregation

Analyze & Act

Gain insights and automate responses to changing conditions.

- Anomaly detection
- Metric math
- Auto Scaling integration

Optimize & Resolve

Reduce MTTR and optimize resource utilization.

- Contributor Insights
- Synthetics monitoring
- Container Insights

Infrastructure Security

Methods for Logging & Monitoring



Log Collection

Centralize data from disparate sources into a unified stream.

- Agent-based (CloudWatch Agent)
- API-based (CloudTrail)
- Flow Logs (VPC Traffic)
- S3 Access Logging



Data Analysis

Transform raw logs into actionable intelligence and trends.

- CloudWatch Logs Insights
- Metric Math & Statistics
- CloudTrail Insights
- Log Streaming to OpenSearch



Proactive Monitoring

Automate responses and alerts based on specific events.

- CloudWatch Alarms (SNS)
- EventBridge Event Rules
- Lambda Auto-Remediation
- Anomaly Detection

Infrastructure Security

Additional Logging & Monitoring Services

AWS Config

Continuously audit and assess configurations of AWS resources.

- Resource Tracking
- Compliance Auditing
- Change Management
- Security Analysis

VPC Flow Logs

Capture information about IP traffic to and from network interfaces.

- Network Troubleshooting
- Security Monitoring
- Usage Analysis
- Inbound/Outbound Data

AWS Security Hub

Centralized view of security alerts and security posture across accounts.

- Aggregated Findings
- Automated Checks
- Best Practice Standards
- Consolidated Dashboards

Infrastructure Security

Centralized Security with AWS Security Hub

Unified Security Posture

AWS Security Hub provides a comprehensive view of your security alerts and security posture across AWS accounts.

- Aggregated Findings: Consolidate alerts from GuardDuty, Inspector, and Macie.
- Automated Compliance: Run continuous, automated configuration checks.
- Standardized Formatting: All findings use the AWS Security Finding Format (ASFF).
- Centralized Dashboard: View all high-priority alerts in a single pane of glass.

Automated Remediation

Go beyond visibility by automating the response to security findings and maintaining best practices.

- Security Standards: Support for CIS Foundations, PCI DSS, and AWS Foundations.
- EventBridge Integration: Trigger Lambda functions or Step Functions for auto-fixes.
- Finding Enrichment: Automatically add context to alerts for faster investigation.
- Cross-Account Aggregation: Manage multi-account organizations from a single master account.


Infrastructure Security
Responding and Managing an Incident

Infrastructure Security

Identifying an Incident



Detection Sources

Identify anomalies through various monitoring signals.

- CloudWatch Alarms
- GuardDuty Findings
- Security Hub Alerts
- User Reports



Analysis & Triage

Determine the scope and severity of the potential threat.

- Log Correlation
- Resource Profiling
- Vulnerability Scan
- False Positive Check



Classification

Categorize the incident to trigger appropriate playbooks.

- Unauthorized Access
- Data Exfiltration
- Denial of Service
- Malware Activity

Infrastructure Security

Discovery & Recognition Services



Amazon GuardDuty

Intelligent threat detection service that monitors for malicious activity.

- Anomalous Behavior
- Credential Exposure
- Malware Detection
- Resource Usage



Amazon Inspector

Automated vulnerability management for workloads across AWS.

- Software Vulnerabilities
- Network Exposure
- Continuous Scanning
- Prioritized Risk Score



Amazon Macie

Discover and protect sensitive data at scale using machine learning.

- PII Discovery
- Data Privacy Monitoring
- Risk Assessment
- S3 Bucket Visibility

Infrastructure Security

Resource Inventory & Compliance

AWS Config Overview

Assess, audit, and evaluate the configurations of your AWS resources.

- Resource Inventory
- Configuration History
- Change Notifications
- Snapshot Relationships

Compliance & Governance

Define rules for provisioning and configuring AWS resources.

- Managed Config Rules
- Custom Lambda Rules
- Conformance Packs
- Continuous Monitoring

Audit & Remediation

Simplify compliance auditing and security analysis.

- Automatic Remediation
- Operational Analysis
- CloudTrail Integration
- Security Analysis

Infrastructure Security

AWS Lambda: Serverless Compute



Event-Driven Execution

Run code in response to triggers without managing servers.

- S3 Object Creation
- DynamoDB Updates
- API Gateway Calls
- SNS Notifications



Automatic Scaling

Precisely scales with the size of the workload automatically.

- Zero to Thousands
- Parallel Execution
- High Availability
- Sub-second Metering



Integrated Security

Fine-grained access control for your functions and data.

- IAM Role Execution
- VPC Support
- Resource-based Policy
- Code Signing

Infrastructure Security

Resolution & Recovery Services



AWS Systems Manager

Automate operational tasks and maintain system compliance during recovery.

- Patch Manager
- Automation Runbooks
- State Manager
- Inventory Tracking



AWS Backup

Centralized backup service to protect and restore data across AWS services.

- Point-in-time Recovery
- Cross-Region Restore
- Backup Vault Lock
- Policy-driven Automation



Elastic Disaster Recovery

Minimize downtime and data loss with fast, reliable recovery of workloads.

- Continuous Replication
- Non-disruptive Testing
- Anytime Drill Launch
- Simplified Failback

Infrastructure Security

Best Practices for Incident Handling

Preparation & Identification

Establish a baseline and detect anomalies early.

- Define IR Plan
- Train Staff
- Set Up Logging
- Threat Detection

Containment & Eradication

Limit impact and remove the root cause.

- Isolate Systems
- Snapshot Evidence
- Patch Vulnerability
- Remove Malware

Recovery & Lessons Learned

Restore services and improve for the future.

- Verify Systems
- Monitor Recovery
- Post-Incident Review
- Update Protocols

Thank You

Infrastructure Security & Compliance

Cloud Security Use Case

Academic Institute Web Hosting

Configuration Settings

- WAF with Rate Limiting
- TLS 1.3 Encryption
- S3 Static Website (Private)
- CloudFront OAC / OAI
- MFA for Admin access
- Log Export to CloudWatch

The DOs

- Use Least Privilege (IAM)
- Automate Patching
- Daily Off-site Backups
- DDoS Protection (Shield)
- Regular Vulnerability Scans
- Student/Staff SSO Sync

The DON'Ts

- Public S3 Buckets
- Hardcoded API Keys
- Shared Admin Credentials
- Ignoring Error Logs
- Over-provisioned Roles
- Default Root User Usage

Cloud Security Use Case

Student Database Software Hosting

Security Configuration

- Database Encryption (AES-256)
- VPC with Private Subnets
- RDS Security Group Lock-down
- Audit Logging (CloudTrail)
- PII Data Masking
- IAM Database Authentication

The DOs

- Enable MFA for All Users
- Rotate Secrets Frequently
- Implement Row-Level Security
- Regular Penetration Testing
- Real-time Anomaly Detection
- Automate Backups & Drills

The DON'Ts

- Expose DB to Public Internet
- Use Default Port Numbers
- Store Plaintext Passwords
- Grant "db_owner" to App
- Ignore Software Patches
- Disable Versioning on S3

Cloud Security Use Case

Software Dev & Lifecycle Hosting

Secure SDLC Config

- Isolated Dev/Test/Prod VPCs
- Git Branch Protection Rules
- SAST/DAST Integration
- Ephemeral Test Runners
- OIDC for CI/CD Pipelines
- Private Container Registry

The DOs

- Sign Commits (GPG/SSH)
- Scan for Secrets in Code
- Use Infrastructure as Code
- Enforce Peer Code Reviews
- Automate Image Patching
- Rotate Access Keys Weekly

The DON'Ts

- Hardcoded Credentials
- Public Dev/Test Endpoints
- Shared Development Logins
- Using 'root' in Containers
- Ignoring Vulnerability Alerts
- Direct Production Hot-fixes

Cloud Security Use Case

Banking Core Software Hosting

Compliance & Encryption

- FIPS 140-2 HSM Integration
- PCI DSS / SOC2 Compliance
- Always-on Disk Encryption
- Bring Your Own Key (BYOK)
- VPC Endpoint Isolation
- Strict Data Residency Control

The DOs

- Enforce Multi-Region HA
- Mandate JIT Admin Access
- Continuous Audit Logging
- Real-time Fraud Detection
- Automate Compliance Scans
- Network Micro-segmentation

The DON'Ts

- Single Point of Failure
- Unencrypted PII Storage
- Shared Cloud Credentials
- Public Internet DB Access
- Over-permissioned IAM Roles
- Ignoring Regulatory Updates

Cloud Security Use Case

EDA & Engineering Software Hosting

High-Performance Config

- Encrypted EBS (AES-256)
- NICE DCV Secure Streaming
- VPC Peering for License Server
- Isolated Compute Clusters
- AppStream 2.0 Security
- FSx for Lustre Encryption

The DOs

- Enforce IP Whitelisting
- Use AD/SSO Integration
- Enable Session Recording
- Monitor License Leakage
- Automate Instance Cleanup
- Encrypt IP Data at Rest

The DON'Ts

- Open SSH to 0.0.0.0/0
- Store Unencrypted Designs
- Shared License Keys
- Ignore Egress Data Flow
- Public Internet Endpoints
- Default OS Passwords

Cloud Security Use Case

Identity & Access Management Setup

Core IAM Configuration

- Least Privilege Principle
- Role-Based Access (RBAC)
- Identity Federation (SAML)
- Hierarchical IAM Groups
- Boundary Policies (SCP)
- Conditional Access Flow

The DOs

- Enforce Mandatory MFA
- Audit Inactive Users
- Use Temporary Credentials
- Enable IAM Access Analyzer
- Regular Policy Reviews
- Tag All IAM Resources

The DON'Ts

- Share Access Keys
- Use Root Account Daily
- Attach Inline Policies
- Hardcode IAM Secrets
- Overlapping Permissions
- Grant "Full Access" Roles

Cloud Security Tools Ecosystem

Open Source & Proprietary Solutions



Open Source Tools

- Falco (Runtime Security)
- Trivy (Vulnerability Scan)
- CloudCustodian (Policy)
- Checkov (IaC Scanning)
- Wazuh (XDR/SIEM)
- Opa (Policy Engine)



Proprietary Platforms

- Palo Alto Prisma Cloud
- Wiz (CNAPP)
- CrowdStrike Falcon
- Aqua Security
- Lacework (Polygraph)
- Orca Security



Cloud Native (CSP)

- AWS GuardDuty/Inspector
- Azure Defender for Cloud
- Google Cloud Security Command Center
- AWS KMS / Azure Key Vault
- Cloud Trail / Sentinel

Cloud Security Threat Landscape

Common Security Issues in Cloud

Misconfigurations

- Unsecured S3 Buckets
- Exposed Database Ports
- Default Security Groups
- Disabled Logging/Audit
- Weak Encryption Specs
- Public Access Assets

Identity Failures

- Inadequate MFA usage
- Excessive Permissions
- Stale User Accounts
- Leaked Access Keys
- Poor Credential Hygiene
- Lack of Role Isolation

External Threats

- Shadow IT Deployments
- Supply Chain Attacks
- API Vulnerabilities
- DDoS Disruptions
- Insider Data Leakage
- Ransomware Infiltration